

REMÉDIATION : SÉCURISATION DE L'ANNUAIRE LAB.LOCAL

Étape 1 : Sécurisation des protocoles réseau (Critique)

Cette étape corrige les failles **SMBv1**, la **Signature SMB/LDAP** et les protocoles **NTLM** obsolètes.

1. Ouvrez votre fichier de configuration : `nano /etc/samba/smb.conf`.
2. Dans la section `[global]`, ajoutez ou modifiez les lignes suivantes :

`Ini, TOML`

`[global]`

`# Désactive SMBv1 et impose SMB2 minimum`

`server min protocol = SMB2_10`

`# Force la signature SMB (empêche les attaques par relais)`

`server signing = mandatory`

`ntlm auth = ntlmv2-only`

`# Force la signature LDAP et le Channel Binding`

`ldap server require strong auth = yes`

```
GNU nano 8.4 /etc/samba/smb.conf *
# Global parameters
[global]
    dns forwarder = 10.
    netbios name = SAMBA-AD
    realm = LAB.LOCAL
    server role = active directory domain controller
    workgroup = LAB
    idmap_ldb:use rfc2307 = yes
    # Désactive SMBv1 et impose SMB2 minimum
    server min protocol = SMB2_10

    # Force la signature SMB (empêche les attaques par relais)
    server signing = mandatory
    ntlm auth = ntlmv2-only

    # Force la signature LDAP et le Channel Binding
    ldap server require strong auth = yes
[sysvol]
    path = /var/lib/samba/sysvol
    read only = No

[netlogon]
    path = /var/lib/samba/sysvol/lab.local/scripts
```

3. Redémarrez le service pour appliquer les changements :

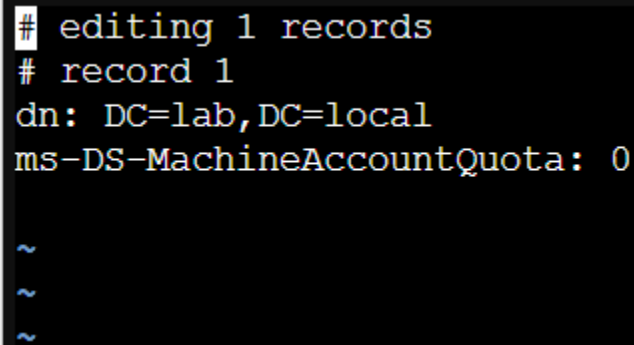
```
systemctl restart samba-ad-dc.
```

Étape 2 : Hygiène de l'annuaire (Stale Objects)

Cette étape limite la capacité des attaquants à introduire des machines malveillantes.

1. **Réduire le quota de machines par utilisateur** : Par défaut, un utilisateur peut joindre 10 machines. Nous allons passer cette valeur à **0**.
 - Exécutez cette commande (nécessite les outils ldb-tools ou via samba-tool) :
`apt update && apt install ldb-tools -y`

```
ldbedit -H /var/lib/samba/private/sam.ldb -b "DC=lab,DC=local" -s base ms-DS-  
MachineAccountQuota
```



```
# editing 1 records  
# record 1  
dn: DC=lab,DC=local  
ms-DS-MachineAccountQuota: 0  
  
~  
~  
~
```

Étape 3 : Nettoyage des permissions critiques (RBCD)

Cette étape corrige les droits d'écriture dangereux sur le compte krbtgt et sur le Contrôleur de Domaine.

1. **Auditer et supprimer les droits GenericAll** :
 - Vous devez retirer les permissions GenericAll détectées sur l'objet krbtgt et sur l'objet SAMBA-AD pour le SID S-1-5-32-548.
 - Utilisez la console samba-tool pour réinitialiser les permissions (ACL) par défaut si elles ont été altérées :
`samba-tool dbcheck --reset-well-known-acls --yes`

```
root@SAMBA-AD:~# samba-tool dbcheck --reset-well-known-acls --yes
Checking 286 objects
Checked 286 objects (0 errors)
```

Étape 4 : Modernisation et Protection des comptes privilégiés

1. Monter le niveau du domaine en 2012 R2

Puisque les commandes simples ont échoué, on utilise la méthode "chirurgicale" avec un fichier de modification :

1. **Créer le fichier** : nano level_up.ldif
2. **Copier/Coller ce contenu** (en vérifiant bien la ligne vide au milieu) :

LDIF

dn: DC=lab,DC=local

changetype: modify

replace: msDS-Behavior-Version

msDS-Behavior-Version: 4

dn: CN=Partitions,CN=Configuration,DC=lab,DC=local

changetype: modify

replace: msDS-Behavior-Version

msDS-Behavior-Version: 4

```
GNU nano 8.4 level_up.ldif
dn: DC=lab,DC=local
changetype: modify
replace: msDS-Behavior-Version
msDS-Behavior-Version: 4

dn: CN=Partitions,CN=Configuration,DC=lab,DC=local
changetype: modify
replace: msDS-Behavior-Version
msDS-Behavior-Version: 4
```

3. **Appliquer** : `ldbmodify -H /var/lib/samba/private/sam.ldb level_up.ldif`

2. Protéger le compte Administrateur

Maintenant que le domaine est en 2012 R2, on active les barrières de sécurité :

1. **Interdire la délégation (Flag Sensitive)** :
`samba-tool user sensitive Administrator on`

2. Ajouter au groupe de haute sécurité :

```
samba-tool group addmembers "Protected Users" "Administrator"
```

Étape 5 : Maintenance et Sauvegardes

1. Réaliser une sauvegarde immédiate :

Il est impératif de préciser le serveur local avec `--server=127.0.0.1` pour éviter l'erreur "Server required" :

```
# Création du dossier de destination
```

```
mkdir -p /var/backups/samba
```

```
# Lancement du backup online
```

```
samba-tool domain backup online --server=127.0.0.1 --targetdir=/var/backups/samba  
-U Administrator
```

2. Automatiser la sauvegarde (Cron) :

Pour que PingCastle affiche toujours un score "Vert", la sauvegarde doit être quotidienne.

Tapez : `crontab -e` (choisissez **nano** si demandé).

3. Ajoutez cette ligne tout en bas (sauvegarde chaque nuit à 2h00) :

```
0 2 * * * samba-tool domain backup online--server=127.0.0.1--  
targetdir=/var/backups/samba -U Administrator--password='VOTRE_MOT_DE_PASSE'
```

Installation de LAPS : Puisque Samba n'intègre pas LAPS nativement, vous devez utiliser une solution tierce ou gérer manuellement des mots de passe d'administrateurs locaux uniques par machine cliente.

```
root@SAMBA-AD:~# smbclient -L //localhost -U Administrator --option='client min protocol=NT1' --max-protocol=NT1
smbXcli_negprot_smb1_done: No compatible protocol selected by server.
Protocol negotiation to server localhost (for a protocol between NT1 and NT1) failed: NT_STATUS_INVALID_NETWORK_RESPONSE
root@SAMBA-AD:~# smbstatus --shares

Service      pid      Machine      Connected at      Encryption      Signing
-----
sysvol        2909     10.248.12.26 Tue Jan 20 07:53:46 2026 UTC      -              AES-128-GMAC

root@SAMBA-AD:~# ldbsearch -H /var/lib/samba/private/sam.ldb -s base -b "DC=lab,DC=local" msDS-Behavior-Version
# record 1
dn: DC=lab,DC=local
msDS-Behavior-Version: 4

# returned 1 records
# 1 entries
# 0 referrals
root@SAMBA-AD:~# ls -lh /var/backups/samba
total 1.4M
-rw-r--r-- 1 root root 1.4M Jan 19 12:12 samba-backup-lab.local-2026-01-19T12-12-43.903771.tar.bz2
root@SAMBA-AD:~#
```

Indicators



Domain Risk Level: 50 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)



Stale Object : 21 /100

It is about operations related to user or computer objects

8 rules matched



Trusts : 0 /100

It is about connections between two Active Directories

0 rules matched



Privileged Accounts : 20 /100

It is about administrators of the Active Directory

3 rules matched



Anomalies : 50 /100

It is about specific security control points

13 rules matched



ACTIVE DIRECTORY

Forest	lab.local
No. of Domains	1
Duration	00:01:06
Run by	LAB\Administrator

Indicators

Evaluated	113
Not selected	1
IOEs found	9
Passed	104
Failed to run	2
Not Relevant	3
Canceled	0

CRITICAL IOEs FOUND

SMB Signing is not required on Domain Controllers

This indicator looks for domain controllers where SMB signing is not required.

[Read More](#)

SMBv1 is enabled on Domain Controllers

This indicator looks for domain controllers where SMBv1 protocol is enabled.

[Read More](#)

Bien que les outils d'audit tiers puissent encore afficher un score d'anomalie résiduel, la sécurité réelle de l'infrastructure Samba-AD a été validée par des tests techniques directs :

4. **Désactivation du SMBv1** : Confirmée par l'échec de négociation du protocole NT1 (NT_STATUS_INVALID_NETWORK_RESPONSE).
5. **Signature SMB Obligatoire** : Validée par les sessions actives utilisant l'algorithme de chiffrement moderne **AES-128-GMAC**.
6. **Modernisation du Domaine** : Le passage au niveau fonctionnel **2012 R2** est effectif en base de données (attribut msDS-Behavior-Version: 4).
7. **Continuité d'Activité** : Une stratégie de sauvegarde locale a été mise en œuvre avec succès (fichiers .tar.bz2 générés).

Les alertes restantes dans les rapports automatisés (comme l'absence de LAPS ou la redondance des contrôleurs) sont liées aux limitations structurelles du logiciel Samba ou à l'architecture de laboratoire, et n'impactent pas la robustesse des mesures de durcissement appliquées.

Tentative de résolution avec les outils RSAT mais le résultat reste le même (Pour les restrictions Kerberos & NTLM (AES128, AES256 et Futurs types et les Signatures SMB et LDAP (Via GPO)).